

Blackwall: 8-minute online pitch, speaker script

10 slides · target 7:30 speaking time, 30 s of slack · about 920 words, roughly 6.5 min at a calm 140 words/minute plus pauses

Online delivery. Share the PDF full screen. The dashboard screenshots are of the current English dashboard, replaying the recorded demo run on synthetic data; the HR prompt in them is Polish, say so once. Point at the reason codes (e.g. *PATH_OUTSIDE_WORKSPACE*) rather than reading small text. Camera on, pause one beat after every slide change.

1 · Title

0:00 – 0:15

“Hi, we are Kacper, Dominik, Dariusz and Marcin, and this is Blackwall. The idea in one line: before an AI agent makes its move, it has to ask us. We built a control layer that decides whether an agent's action may happen, before it happens, and explains why.”

2 · The problem

0:15 – 0:55

“Agents no longer just answer questions. They read files, call APIs and run commands. The challenge brief names the risks, and we saw all of them. One: agents reach resources they shouldn't. Two: they obey instructions hidden in text, that is prompt injection, and their answers can leak secrets. Three: they can burn budget in loops nobody predicted. In the banking industry we have to be the most cautious with client data, deal secrets and employee records.”

3 · Our idea

0:55 – 1:50

“Our answer is one layer between the agent and the world. There are two doors into it: a plugin that checks every tool call of the Pi agent, and an OpenAI-compatible gateway, so any client can be governed by changing one base URL. Inside, one central policy drives four things: deterministic rules, a semantic review of proposed actions by Jev, and topic supervision with embeddings and a guardian model. The answer is always allow, ask the user, or deny, with a reason code and a policy version. Tools and models run only after an allow, with a one-time grant checked again just before execution. Everything lands in an audit trail and a dashboard.”

4 · Hybrid defense

1:50 – 2:30

“The brief asks for a hybrid, and we made the split simple. Rules are fast and always give the same answer: they limit which files an agent may touch and where it may send data, protect secrets and personal data, cap token spending, and block known attacks. AI handles meaning: it reviews risky actions before they run, notices when a conversation turns sensitive, and judges whether policy is broken, with evidence. You choose how strict it is: permissive, standard or strict. Three principles hold it together. A model can never lift a hard ban. No answer from a required control means no approval. And when the system is unsure, a human decides.”

5 · Finance scenarios

2:30 – 3:35

“Here is how it plays out with the same agent in three finance conversations, all on synthetic data. In KYC onboarding the agent drafts a client file after a one-time approval, but when it tries to read another client's folder, the read is refused before it runs. In a confidential M&A analysis, an authorized POST goes through, but a publication planted in a document is stopped, and the receiver gets zero requests. In HR, a general question about performance reviews is fine. Asking it to rank two named employees and pick who to dismiss ends the session. These are screenshots of our dashboard, replaying the recorded demo run; the HR prompt was typed in Polish. The reason codes are the part to read.”

6 · Topic supervision

3:35 – 4:30

“The HR case shows our most unusual control: it stops a conversation, not just a call. An embedding match against a topic catalog labels the session. That starts one guardian verdict, which applies the policy and quotes the evidence. If it confirms a violation, the session is terminated before the answer is released or an action runs, and every later request is denied. A topic alone is not a violation. If the guardian is unsure, the session waits for an administrator. Latency, per stage in our final run: topic detection 683 milliseconds at p95, the guardian about 2.3 seconds, and it only runs when a topic matched. Small sample, single stages.”

7 · One policy, changed live

4:30 – 5:20

“Everything is driven by one policy file. Three strictness levels, permissive, standard and strict, change thresholds and what gets blocked versus redacted. Budgets are reserved before every model call: tokens, tool attempts, model requests and wall time per session. The threat feed carries nine signatures, such as unsafe pickle and torch.load deserialization, trust_remote_code, curl-pipe-shell and reverse shells. And you can change all of it live. Publish a new version from the Policies tab, and the next decision uses it, no restart; old approvals expire. A broken or stale publication leaves the active policy untouched.”

8 · Dashboard and audit

5:20 – 6:00

“Security teams and managers get the same data from one place: live sessions per user, every decision with its reason and policy version, latency per stage, tokens, and a JSONL export. One detail we care about: an allow does not prove an operation ran, so the audit tracks the decision, the approval and the execution report separately.”

9 · Tests

6:00 – 6:45

“The suite has positive and negative cases, and the negative ones check the effect, not just the verdict. The file was not created, the receiver got no request, the model never saw the prohibited content, the secret never reached the UI. In the final run: 143 of 143 unit tests, 33 of 33 live API checks, and 12 of 12 end-to-end tests with a real Pi agent. In our semantic evaluation, 15 of 15 violations ended and none of 19 legitimate sessions were wrongly terminated. The corpus is small and hand-written, so this is evidence, not a production guarantee.”

10 · Limits and close

6:45 – 7:30

“Honest limits. There is no OS sandbox: Jev reviews a command, it cannot contain it. The plugin and gateway are the enforcement point. This is a local MVP with SQLite, no SSO, no MCP, and it runs on OpenAI and Jev, with no local-model backend yet. The path to a pilot is a sandboxed runner, a central control plane with SSO, MCP and agent-to-agent adapters, and local models behind the same gateway. We would love to try this on a real use case. So: give us a prompt we have never seen, or change the policy live, and watch the next decision change. Thank you.”

If you run long, cut in this order:

- Slide 4: skip the two lists, say only the three principles (saves 15 s).
- Slide 7: skip the threat-feed examples (10 s).
- Slide 8: one sentence only (15 s).

Likely questions: “Does it run without paid APIs?” Not today; the deterministic layer and *npm test* do. “Can the agent bypass it?” Not through the plugin or gateway; a host admin can disable the plugin, and there is no sandbox. “What if the AI is wrong?” Rules run first, a model cannot lift a hard ban, uncertainty goes to a human.